What the patch report needs — one page for whoever approves it

Get-PatchStatus-Permissions.md - 03 November 2026

`Get-PatchStatus.ps1` reports how far behind each SQL Server and the Windows under it is. It is **read-only**: it installs nothing, writes nothing to any SQL Server, changes no setting, and reads no data out of any database.

The short version

One service account. On SQL Server, a login that can connect and nothing else. On Windows, read access to one registry key.

The ask, in full

#	What	Where	Why
1	A domain account in no privileged group	Active Directory	the identity the report runs as
2	`CREATE LOGIN [DOM\svc_patchreport] FROM WINDOWS;`	every SQL Server instance	read its version and edition
3	User right **Access this computer from the network**	every target server	needed to connect at all
4	**Remote Registry** service running, and read on one key (below)	every target server	read the Windows build number
5	UDP 1434, TCP 1433 (plus any fixed instance ports), TCP 445	firewall, reporting box -> targets	instance discovery, SQL, registry
6	Outbound HTTPS to two Microsoft hosts (below)	firewall, reporting box only	Microsoft's own patch data — **avoidable**, see the last section

Nothing in this list is needed on the box the report runs *from* beyond the account being able to log on to it and write the output file where you point it.

2. On SQL Server: this and nothing else

```
CREATE LOGIN [CONTOSO\svc_patchreport] FROM WINDOWS;
-- No server role. No database user. No GRANT. Stop here.
```

A new login gets `CONNECT SQL` by default, and that is the whole requirement. The report reads only these, all of which are available to `public`:

Reads	Returns
`SERVERPROPERTY('ProductVersion')`	16.0.4215.2
`SERVERPROPERTY('Edition')`	Standard Edition (64-bit)
`SERVERPROPERTY('ProductUpdateLevel')`	CU14
`SERVERPROPERTY('ComputerNamePhysicalNetBIOS')`	which machine the instance is on
`@@SERVERNAME`, `@@VERSION`	name, and whether it is Linux
`IS_SRVROLEMEMBER('sysadmin')`	its *own* membership, to explain itself in the report

Explicitly not needed: `sysadmin`, `serveradmin`, `securityadmin`, `VIEW SERVER STATE`, `VIEW ANY DEFINITION`, `db_datareader`, or access to any user database.

This was verified by creating a login with nothing granted, connecting as it, and running the report's exact query. It worked, and the same login was refused when it tried to:

- connect to a user database
- read a user database's tables
- see any session other than its own
- list the databases' files on disk
- create, alter or drop anything

4. On Windows: read one key

The Windows half of the report needs four values from one key:

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion
    CurrentBuild        InstallationType
    UBR                 ProductName
```

The built-in `Users` group already has read on that key on a default install, so in practice this item is **"start the Remote Registry service"** rather than an ACL change. The account needs no other registry access and no local administrator rights.

If Remote Registry is not allowed

There are two other outcomes, and it is worth being explicit about the trade:

Instead	What it costs
Give the account `sysadmin` on SQL Server, so the report can read the key through `xp_regread`	A great deal — `sysadmin` is total control of the instance. **Not recommended.**
Allow neither	Nothing breaks. Every SQL Server result is still produced; the Windows rows say the build could not be read and suggest running it on the server itself.

The report is designed for the third outcome to be acceptable. Do not grant `sysadmin` to get a build number.

Optional: service enumeration

The report asks the SQL Browser (UDP 1434) which instances exist, and also reads the Windows service list to catch instances whose service is **stopped**. The service list needs read access to the Service Control Manager, which authenticated users have by default; some hardening baselines remove it. If it is unavailable, discovery still works through the SQL Browser — you simply will not see instances that are turned off.

6. The two Microsoft hosts, or no internet at all

Host	What for
`https://learn.microsoft.com`	the published SQL Server build list
`https://api.msrc.microsoft.com`	Microsoft's security update data for Windows

Only the machine running the report needs these, and only outbound. **If that is not acceptable, it can run with no internet access whatsoever:** on any connected machine, run

```
.\Get-PatchStatus.ps1 -SaveReference patch-reference.json
```

copy `patch-reference.json` next to the script on the isolated box, and it will use that instead. The report warns if the file is more than 40 days old.

What SQL Server will show the account anyway

These are SQL Server's own defaults for any login, not permissions being requested, and the report does not use any of them. Listed so that nobody discovers them later and assumes the report asked for them:

Visible by default	Note
The names of other logins (`sys.sql_logins`)	server-level metadata is visible to all logins
Which databases exist (`sys.databases`)	names only — it cannot connect to them
`msdb.dbo.backupset` (backup history)	`msdb` has `guest` enabled out of the box

If the last one matters to you, `USE msdb; REVOKE CONNECT FROM guest;` removes it — check nothing else on the instance relies on it first.

Summary for a change record

> *A read-only service account with a SQL Server login (no roles, no database access), the "Access this computer from the network" right, and read access to one Windows registry key via the Remote Registry service. Outbound HTTPS to two Microsoft hosts, or an offline reference file instead. The account cannot read application data, cannot connect to any user database, and cannot change anything.*